JWT ile API Güvenliği

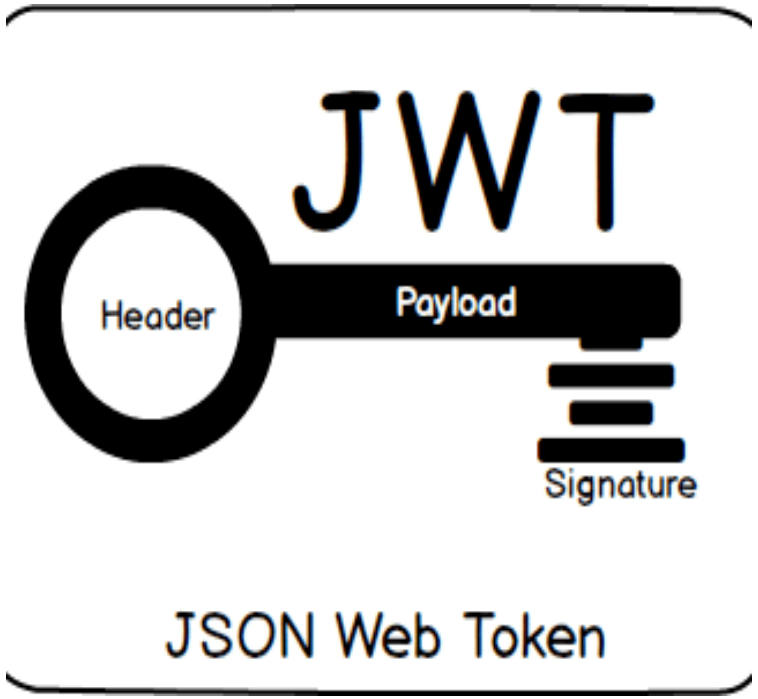
Canberk Sezgin 1030510698

Genel Bakış

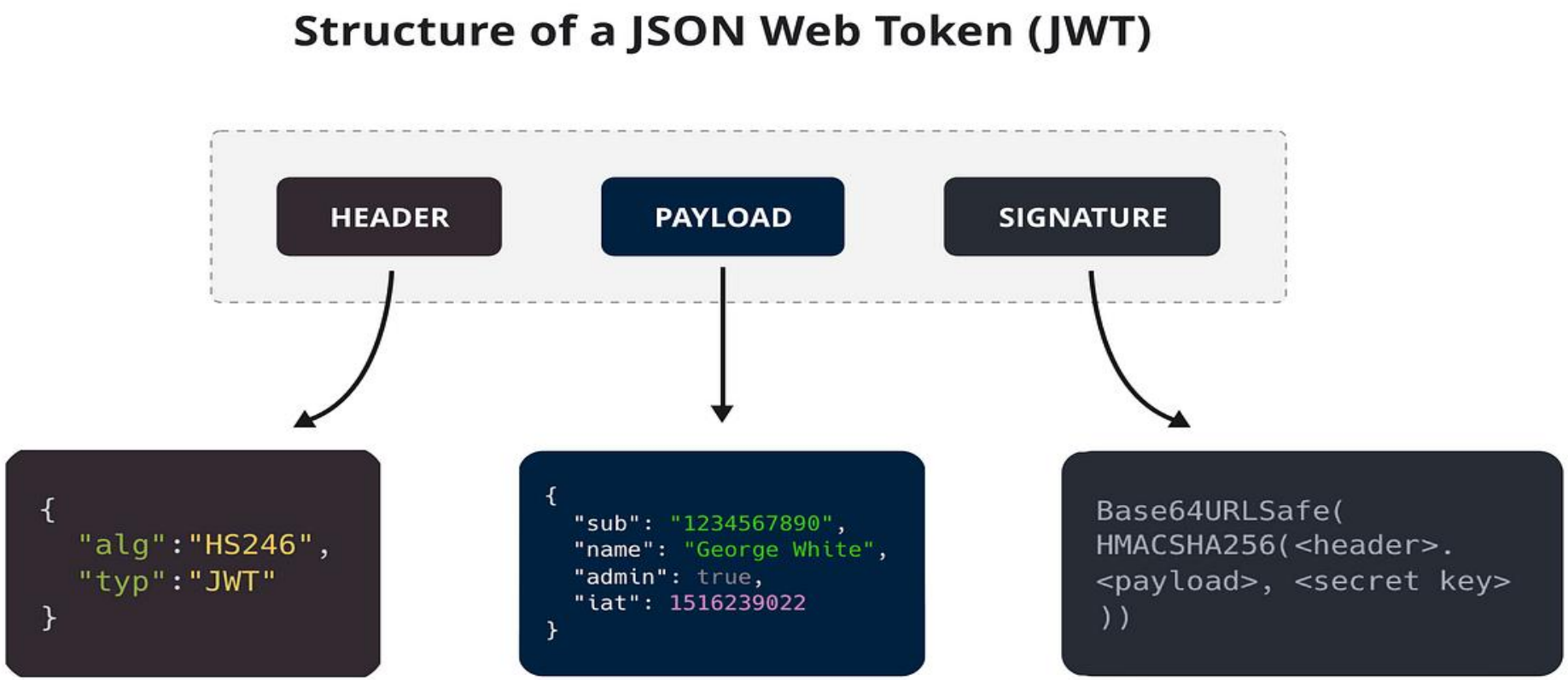
1. Jwt nedir?
2. Jwt nasıl çalışır?
3. API nedir?
4. Güvenlik açıkları
5. Avantaj dezavantaj karşılaştırması

JWT NEDİR

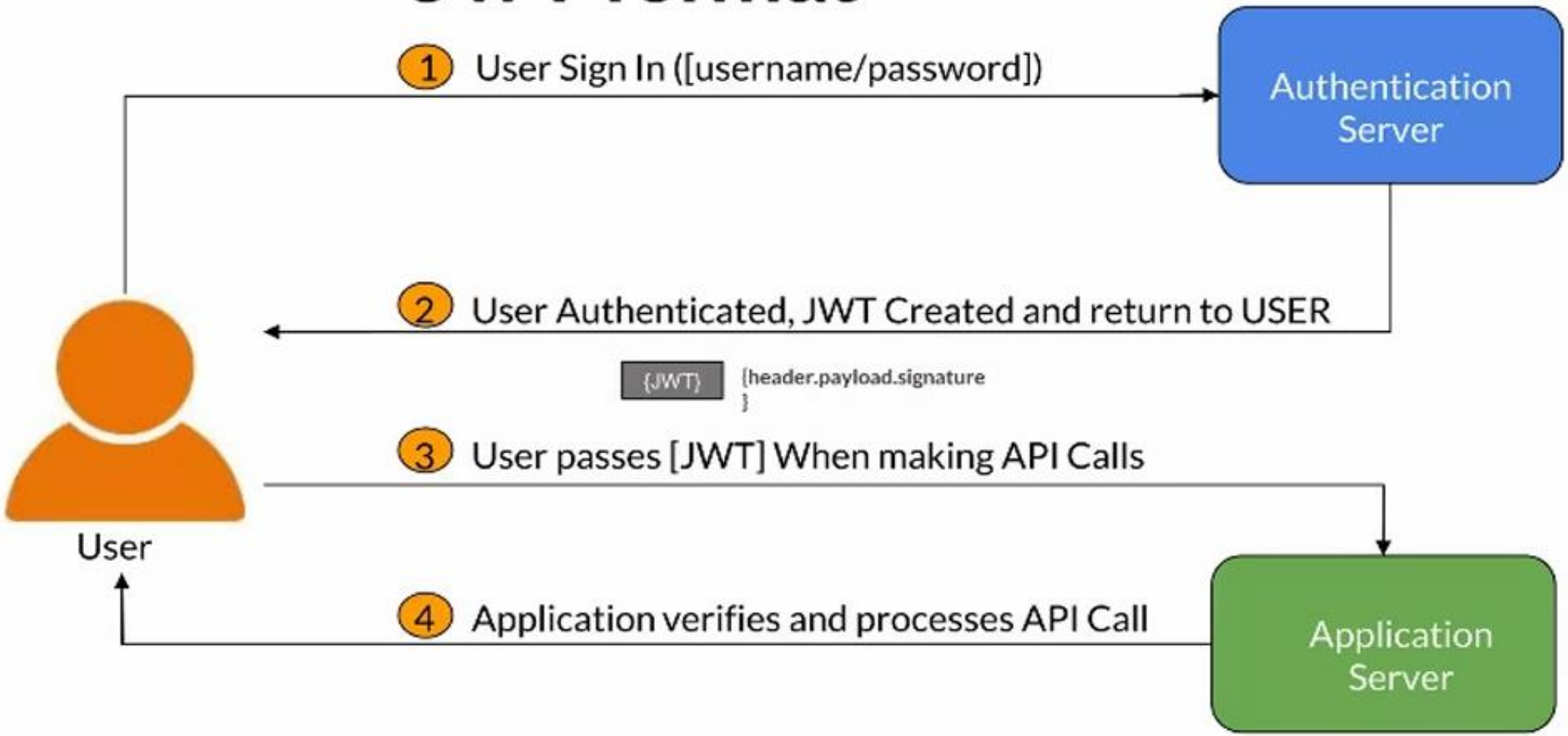
- JWT (JSON Web Token), JSON formatında veri taşıyan dijital bir token yapısıdır.
- Kompakt ve URL-safe olduğundan, HTTP isteklerinde kolaylıkla taşınabilir.
- Genellikle kimlik doğrulama (authentication) sonrası yetkilendirme (authorization) amacıyla kullanılır.
- İmzalama için genellikle HS256 (HMAC) veya RS256 (RSA) algoritmaları kullanılır bu bilgi, dijital olarak imzalandığı için doğrulanabilir ve güvenilirdir.



JWT NASIL ÇALIŞIR



JWT format


1 User Sign In ([username/password])
Authentication Server
2 User Authenticated, JWT Created and return to USER
{JWT}
{header.payload.signature
}
3 User passes [JWT] When making API Calls
User
4 Application verifies and processes API Call
Application Server

Token Ömrü ve Refresh Token

- **Kısa Ömürlü (Short-Lived) JWT'ler:**
- Access Token'ların (JWT) ömrü genellikle çok kısadır (örn: 5-10 dakika).
- **Sebep:** JWT'ler *stateless* olduğu için sunucu tarafından anında iptal edilemezler. Çalınmaları durumunda hacker'a verilen zaman penceresini daraltmak şarttır.
- **Refresh Token Nedir?**
- Giriş (Login) esnasında JWT ile birlikte verilen **ikinci bir anahtardır.**
- JWT'nin aksine veri tabanında kayıtlıdır (Stateful) ve ömrü uzundur (örn: 30 gün).
- **Nasıl Çalışır?**
- JWT'nin süresi bittiğinde, kullanıcıdan tekrar şifre istenmez.
- Uygulama arka planda Refresh Token'ı sunucuya yollar ve yepyeni bir JWT alır.
- **Üst Düzey Güvenlik (Rotation):**
- **Refresh Token Rotation:** Her yenileme işleminde eski Refresh Token silinir ve kullanıcıya yeni bir tane verilir. böylece bu token da çalınırsa tespit edilebilir.

API Nedir

- **API (Uygulama Programlama Arayüzü):** İstemci (uygulama) ile sunucu arasındaki veri alışverişini sağlayan köprüdür.
- **İstek-Yanıt (Request/Response) Döngüsü:** İstemci bir işlem talep eder (Request), sunucu işlemi gerçekleştirip sonucu döndürür (Response).
- **Endpoint (Uç Nokta):** Sunucu üzerindeki spesifik işlemlere (şarkı açma, hesap silme vb.) açılan özel kapılardır (URL'ler).
- **Güvenlik ve JWT'nin Rolü:** API kapıları internete açık olduğu için her gelen isteğin kimliği doğrulanmalıdır. İstemci, isteğin (Request) içine JWT ekler; sunucu bu token'ın imzasını doğrulayarak yetki kontrolü yapar.

Güvenlik Açıkları

- None Algorithm saldırısı: alg alanı "none" yapılarak imza atlanmaya çalışılır → sunucu algoritma kontrolü yapmalı
- Brute Force: zayıf secret key tahmin edilerek token üretilir → güçlü, rastgele secret key kullan
- XSS: token LocalStorage'da saklanıyorsa JS ile çalınabilir → token'ı HttpOnly cookie'de sakla
- Token Hijacking: çalınan token ile kimlik taklidi → kısa ömürlü token + refresh token rotation

AVANTAJ

- Stateless yapı: sunucu oturum tutmaz, milyonlarca kullanıcı aynı maliyetle işlenir
- Hızlı doğrulama: her istek için veritabanı sorgusu yok, imza kontrolü yeterli
- Taşınabilir: mobil, web, mikroservisler her platformda çalışır
- Kendi kendine yeterli: kullanıcı bilgisi token içinde, ekstra sorgu gerekmez

DEZAVANTAJ

- İptal edilemiyor: token çalınsa bile süresi dolana kadar geçerli, sunucu durduramaz
- Payload herkese açık: base64 ile encode edilmiş, şifreli değil hassas veri koyma
- Boyut sorunu: her istekte header içinde taşınıyor, payload büyüdükçe bant genişliği artar
- Secret key riski: key ele geçirilirse tüm sistem tehlikeye girer

Kaynakça

- https://medium.com/@extio/understanding-json-web-tokens-jwt-a-secure-approach-to-web-authentication-f551e8d66deb
- https://blog.bytebytego.com/p/ep164-jwt-simply-explained
- https://stytch.com/blog/what-are-refresh-tokens/
- https://www.youtube.com/watch?v=Y2H3DXDeS3Q